

CIA Project — I-NSA-801

Complete Team Fix Report

Epitech Digital | May 2026 | Jeet · Tejaswini · Parth

Team Overview

Member	Responsibilities	Fixes
Jeet	Found ALL 11 original vulnerabilities (V1–V11). Fixed V1, V4, V5, V6, V7, V8, V9, V10, V11.	9
Tejaswini	Fixed all code bugs (C), security hardening (H), medium/low (M/L), VM/OS hardening (N), repository hygiene (R), and all project requirements.	49
Parth	Fixed V2, V3 (deploy to VM2), N2, N6–N9 on VM2, V11 deploy.	4+

CRITICAL

Infrastructure

ID	Issue	VM	Fixed By	Fix Applied	Status
V1	Empty root password on VM1	VM1	Jeet	passwd root — set strong root password	Fixed

Code — P0 Bugs

ID	Issue	File	Fixed By	Status
C1	checkRole.ts — no return after 401 response, Express continues processing on deleted-user JWT	checkRole.ts	Tejaswini	Fixed
C2	checkJwt.ts — no return after 401 response, request falls through to next handler	checkJwt.ts	Tejaswini	Fixed
C3	AuthController — missing return statements in login and changePassword handlers	AuthController.ts	Tejaswini	Fixed
C8	Hardcoded JWT secret and DB credential fallbacks — app must throw on startup if env vars are missing	config.ts, ormconfig.js	Tejaswini	Fixed
R8	docker-compose MYSQL_ROOT_PASSWORD not sourced from env_file — was hardcoded	docker-compose.yml	Tejaswini	Fixed
R13	README.md — admin migration instructions were incorrect and stale	README.md	Tejaswini	Fixed

HIGH

Infrastructure

ID	Issue	Location	Fixed By	Fix Applied	Status
V2	Hardcoded JWT secret in source code	VM2 code	Parth	Removed fallback — <code>getEnv()</code> throws if <code>JWT_SECRET</code> is missing or too short	Fixed
V3	Hardcoded DB credentials in source	VM2 code	Parth	All DB vars required from environment, throws on startup if missing	Fixed
V4	Auto admin:admin migration running in container	VM2 code	Jeet	Deleted migration file from container image	Fixed
V5	Hardcoded Gitea credentials in docker-compose	VM2	Jeet	Rotated all passwords in docker-compose.yml	Fixed
V6	Weak passwords on VM2, VM3, VM4	All VMs	Jeet	Changed to strong passwords on all VMs	Fixed

Code — P1 Bugs

ID	Issue	File	Fixed By	Status
C4	JWT token read from non-standard header — must use Authorization: Bearer scheme	checkJwt.ts	Tejaswini	Fixed
C5	swagger-stats UI exposed publicly — live API request metrics visible to anyone	index.ts	Tejaswini	Fixed
C6	Swagger UI /api-docs publicly accessible — exposes full internal API structure	index.ts	Tejaswini	Fixed
C7	CORS set to wildcard origin (*) — allows any website to make authenticated API calls	index.ts	Tejaswini	Fixed
C9	synchronize:true enabled in production — TypeORM auto-modifies DB schema on every startup	ormconfig.js	Tejaswini	Fixed
C10	--inspect flag present in production start script — exposes Node.js V8 debugger	package.json	Tejaswini	Fixed
C11	Dockerfile runs application as root — all containers must run as service-web user	Dockerfile	Tejaswini	Fixed
H2	No password complexity rules — added min 12 chars with upper, lower, digit and symbol	User.ts	Tejaswini	Fixed
H3	No rate limiting on auth routes — added 10 requests/min per IP on login and register	index.ts	Tejaswini	Fixed
H6	Auth cookie missing secure and SameSite flags — set secure=true, SameSite=strict, 15min expiry	account.actions.ts	Tejaswini	Fixed
H7	Frontend URL hardcoded to http:// — now picks scheme from window.location.protocol	account.actions.ts	Tejaswini	Fixed

VM / OS — P1

ID	Issue	VM	Fixed By	Fix Applied	Status
N1	Unknown user soupeladmin present on VM1	VM1	Tejaswini	<code>userdel -r soupeladmin</code>	Fixed

ID	Issue	VM	Fixed By	Fix Applied	Status
N3	DB root password leaked in bash history on VM3	VM3	Tejaswini	shred -u bash_history then recreate with chmod 0600	Fixed
N5	Portainer listening on 0.0.0.0:9000 — publicly accessible	VM3	Tejaswini	Recreated Portainer container bound to 127.0.0.1 only	Fixed
N6	No firewall configured on any VM	VM1,3,4	Tejaswini	firewalld installed and configured (VM2 pending — Parth)	Partial

MEDIUM

Infrastructure

ID	Issue	Location	Fixed By	Fix Applied	Status
V7	API logs sensitive data — 3 morgan lines leaked auth tokens	VM2 code	Jeet	Removed 3 sensitive morgan logging lines from index.ts	Fixed
V8	FTP server (proftpd) running on VM1	VM1	Jeet	docker stop + docker rm m1_proftpd_1	Fixed
V9	MySQL port 3306 exposed publicly on VM4	VM4	Jeet	Bound MySQL to 127.0.0.1:3306	Fixed

Security Hardening — P2

ID	What Was Hardened	File	Fixed By	Status
H1	bcrypt cost factor raised from 8 to 12	User.ts	Tejaswini	Fixed
H4	Login timing oracle — dummy bcrypt hash ensures equal response time for unknown usernames	AuthController.ts	Tejaswini	Fixed
H5	JWT sliding refresh token only issued within 5 minutes of expiry	checkJwt.ts	Tejaswini	Fixed
M2	Helmet configured with explicit CSP, HSTS (1yr), referrer-policy no-referrer, frameguard deny	index.ts	Tejaswini	Fixed
M3	Body validation middleware (needFields) added to all admin user routes	routes/user.ts	Tejaswini	Fixed
L2	.dockerignore added — .env file no longer copied into Docker image layer	.dockerignore	Tejaswini	Fixed
R2	Root .gitignore file was encoded as UTF-16 — rewritten in UTF-8	.gitignore	Tejaswini	Fixed
R5	front_student/.env committed to repo — deleted and replaced with .env.example	.env / .env.example	Tejaswini	Fixed
R9	Frontend docker-compose had REACT_APP_API_URL hardcoded — moved to build-arg	docker-compose.yml	Tejaswini	Fixed
R10	Frontend Dockerfile updated to accept REACT_APP_API_URL as build-arg at image build time	Dockerfile	Tejaswini	Fixed

VM / OS — P2

ID	Issue	VM	Fixed By	Fix Applied	Status
N2	World-readable .env on VM1 (chmod 644)	VM1	Parth	chown + chmod 600 /home/service-web/front/.env	Pending
N4	service-web user missing on VM3	VM3	Tejaswini	useradd, added to docker group, locked login shell	Fixed

LOW

Infrastructure

ID	Issue	Location	Fixed By	Fix Applied	Status
V10	Broken OctoberCMS container still running on VM3	VM3	Jeet	docker stop brave_napier	Fixed
V11	Root SSH login enabled on all VMs	All VMs	Jeet	Documented — apply PermitRootLogin no once a non-root user is created	Pending

Code — P3

ID	Fix	File	Fixed By	Status
M4	Removed dead bank field from JWT payload	checkJwt.ts	Tejaswini	Fixed
M5	Fixed swagger-jsdoc glob pattern to point at files that actually exist	index.ts	Tejaswini	Fixed
L3	Frontend Dockerfile pinned to nginx:1.27-alpine-slim for reproducible builds	Dockerfile	Tejaswini	Fixed
R14	AI-style comments and markers scrubbed from all 13 patched source files	13 files	Tejaswini	Fixed

VM / OS — P3

ID	Issue	VM	Fixed By	Fix Applied	Status
N7	postfix mail server running unused on port 25	All VMs	Tejaswini	systemctl disable --now postfix (VM2 pending — Parth)	Partial
N8	Old 6-year-old containers still running with embedded secrets	All VMs	Tejaswini	docker container prune -f (VM2 pending — Parth)	Partial
N9	bash_history contains sensitive audit commands on VM1 and VM3	VM1, VM3	Parth	cat /dev/null > /root/.bash_history && history -c	Pending

Repository Hygiene — P3

ID	What Was Fixed	Fixed By	Status
R1	Deleted 134 macOS ._* binary artifact files from the repository	Tejaswini	Fixed
R3	back_student/.gitignore expanded with missing patterns (build, sqlite, env)	Tejaswini	Fixed
R4	front_student/.gitignore created from scratch (file was completely missing)	Tejaswini	Fixed

ID	What Was Fixed	Fixed By	Status
R6	back_student/.env.example created with all required environment variables documented	Tejaswini	Fixed
R7	front_student/package-lock.json (716KB) removed — was incorrectly committed	Tejaswini	Fixed
R11	back_student/test directory — contained a 16KB SQLite DB file with real data rows	Tejaswini	Fixed
R12	front_student/_config.yml Jekyll leftover file deleted from repository	Tejaswini	Fixed

Final Totals

Severity	Total Issues	Jeet	Tejaswini	Parth	Fixed	Partial / Pending
Critical	6	1	5	0	6	0
High	18	5	11	2	17	1
Medium	14	3	9	1	12	2
Low	18	2	14	1	14	4
Total	56+	11	39	4	49	7